

بسمه تعالی



دانشگاه صنعتی اصفهان
دانشکده مهندسی برق و کامپیوتر
آزمایشگاه شبکه

زمستان ۱۴۰۳
دکتر فانیان، دکتر حیدرپور

پیش گزارش آشنایی و محافظت در برابر حملات جعل در سوئیچ

فهرست مطالب

<u>صفحه</u>	<u>عنوان</u>
۲	فهرست مطالب
۳	حمله‌ی جعل DHCP Spoofing
۳	دفاع در برابر حمله‌ی DHCP Spoofing
۱۰	حمله ARP Spoofing
۱۰	دفاع در برابر ARP Spoofing
۱۲	حمله جعل IP Spoofing
۱۳	دفاع در برابر حمله‌ی جعل IP Spoofing
۱۴	ابزار hping3
۱۵	امنیت اتصال به تجهیزات شبکه

حمله‌ی جعل (DHCP Spoofing)

در جلسات قبل با سرور DHCP و نقش آن در شبکه آشنا شدید. همان‌طور که می‌دانید، سرور DHCP در پاسخ به یک درخواست DHCP از سمت یک کاربر، طی چندین پیام در نهایت آدرس IP اختصاص داده شده به کاربر، آدرس IP درگاه پیش‌فرض (Default Gateway) و آدرس سرور DNS را برای کاربر ارسال می‌کند. همچنین گفته شد که اگر چندین پاسخ DHCP به سمت کاربر ارسال شود، کاربر اولین پاسخ را قبول کرده و از باقی پاسخ‌ها صرف‌نظر خواهد کرد. در این حالت، اگر مهاجمی بتواند سریع‌تر از سرور DHCP، پاسخ جعلی خود را به دست کاربر برساند، امنیت کاربر به خطر خواهد افتاد.

مهاجم با جعل پاسخ DHCP می‌تواند آدرس درگاه پیش‌فرضی که برای قربانی ارسال می‌کند را برابر با آدرس IP خودش قرار دهد. در این صورت تمام بسته‌های ارسالی از سمت قربانی که به مقصد خارج از شبکه ارسال می‌شوند ابتدا به ماشین مهاجم می‌رسد.

در حالتی دیگر، مهاجم می‌تواند آدرس سرور DNS ارسالی برای قربانی را برابر با آدرس یک سرور DNS تحت کنترل خود قرار دهد. در این حالت، پرسمان‌های DNS قربانی به سمت سرور DNS تحت کنترل مهاجم ارسال می‌شود که مهاجم می‌تواند در پاسخ به پرسمان ارسال‌شده، هر آدرس IP دلخواهی را به عنوان پاسخ ارسال کند. در این صورت، مهاجم می‌تواند قربانی را به سمت دامنه‌ای جعلی با ظاهری شبیه به دامنه مورد نظر قربانی هدایت کند.

شکل پیشرفته‌تر حمله‌ی DHCP Spoofing:

در این نوع حمله، مهاجم با ارسال تعداد زیادی پیام DHCP Discover، سرور واقعی DHCP را آن‌قدر درگیر تخصیص آدرس و مدیریت منابع می‌کند که دیگر قادر به پاسخ‌گویی مناسب به درخواست‌های واقعی کاربران نباشد. پس از آن، مهاجم نقش سرور DHCP را به عهده می‌گیرد و با ارسال پیام‌های جعلی از نوع DHCP Offer و DHCP ACK، اطلاعات نادرست از جمله آدرس درگاه پیش‌فرض و سرور DNS تحت کنترل خود را برای کاربران ارسال می‌نماید. این روش باعث می‌شود کاربران به‌طور کامل به زیرساخت جعلی مهاجم وابسته شده و تمامی ترافیک آن‌ها قابل رهگیری، تحلیل یا حتی تغییر باشد.

دفاع در برابر حمله‌ی DHCP Spoofing (DHCP Snooping)

برای مقابله با حمله‌ی جعل DHCP، دو راهکار اصلی معرفی می‌شود. یکی از این راهکارها تقسیم پورت‌های سوئیچ به دو دسته قابل اعتماد (Trusted) و غیرقابل اعتماد (Untrusted) است. به عبارت دقیق‌تر، پورت‌های Access را به عنوان پورت‌های غیرقابل اعتماد تعریف می‌کنیم تا سوئیچ پیام‌هایی که از نوع پاسخ‌های DHCP

هستند مانند DHCP Offer، DHCP ACK و موارد مشابه را از این پورت‌ها عبور ندهد.

در عوض، تنها پیام‌های DHCP Discovery و DHCP Request از سوی این پورت‌ها مجاز به عبور هستند؛ چرا که این پیام‌ها مربوط به آغاز فرایند درخواست آدرس از سوی کلاینت می‌باشند و نه تخصیص آن از سوی سرور.

با اعمال این راهکار، کاربرانی که از طریق پورت‌های غیرقابل اعتماد به شبکه متصل می‌شوند، قادر به ارسال پاسخ‌های جعلی DHCP در سطح شبکه نخواهند بود و بدین ترتیب، از اجرای حمله DHCP Spoofing تا حد زیادی جلوگیری می‌شود.

برای دفاع در برابر حمله‌ی منع خدمت علیه سرور DHCP، مدیر شبکه می‌تواند نرخ ارسال درخواست‌های DHCP روی پورت‌های دسترسی را به گونه‌ای محدود کند که اگر تعداد درخواست‌های ارسالی از طریق یک پورت از مقدار مشخص شده فراتر رود، پورت مذکور به صورت خودکار غیرفعال (خاموش) شود.

در ادامه، دستورات مربوط به فعال‌سازی این راهکار دفاعی در سوئیچ‌ها معرفی می‌شود. به طور کلی، برای تعریف پورت‌های قابل اعتماد و غیرقابل اعتماد، ابتدا باید قابلیت DHCP Snooping را به صورت سراسری یا برای یک VLAN مشخص فعال نمود. سپس پورت‌های قابل اعتماد به صورت صریح تعریف می‌گردند. توجه داشته باشید که به صورت پیش فرض، پس از فعال‌سازی DHCP Snooping، تمامی پورت‌ها در وضعیت غیرقابل اعتماد قرار دارند.

فعال‌سازی DHCP Snooping به صورت سراسری

```
Switch(config)# ip dhcp snooping
```

فعال‌سازی DHCP Snooping برای VLAN‌های خاص

```
Switch(config) # ip dhcp snooping vlan 10
```

فعال‌سازی Option-82 برای پیام‌های DHCP

در پیام‌های DHCP می‌توان فیلدی به نام Option 82 اضافه کرد که به سرور DHCP کمک می‌کند تا تخصیص آدرس IP به کلاینت‌ها را به صورت دقیق‌تر و کنترل‌شده‌تری انجام دهد. این فیلد که به عنوان DHCP Relay Agent Information Option نیز شناخته می‌شود، مجموعه‌ای از اطلاعات مربوط به منبع درخواست را در خود نگه‌داری می‌کند.

فیلد Option 82 به طور معمول شامل اطلاعاتی نظیر پورت فیزیکی سوئیچ یا شماره VLAN متصل به کلاینت، آدرس MAC کلاینت و سایر جزئیات مربوط به موقعیت فیزیکی کلاینت در شبکه است. این اطلاعات برای

شناسایی دقیق موقعیت کلاینت و پیاده‌سازی سیاست‌های امنیتی و مدیریتی در تخصیص آدرس IP به کار می‌روند. به صورت پیش فرض، پس از فعال‌سازی DHCP Snooping، فیلد Option 82 نیز در پیام‌های DHCP گنجانده می‌شود. برای فعال‌سازی صریح این فیلد، می‌توان از دستور زیر در محیط پیکربندی سوئیچ استفاده کرد:

```
Switch(config) # ip dhcp snooping information option
```

اجازه عبور فیلد Option-82 در پورت غیرقابل اعتماد

به صورت پیش فرض، پس از فعال‌سازی فیلد Option 82، این فیلد تنها از طریق پورت‌های Trusted (قابل اعتماد) عبور داده می‌شود و از پورت‌های Untrusted (غیرقابل اعتماد)، حذف خواهد شد. این رفتار برای جلوگیری از جعل اطلاعات مکانی توسط کلاینت‌ها در نظر گرفته شده است.

با این حال، در برخی سناریوهای خاص، ممکن است نیاز باشد تا این فیلد از پورت‌های Untrusted نیز عبور کند؛ به عنوان مثال، در شرایطی که یک کلاینت به طور مستقیم به سوئیچ متصل نیست و از طریق یک سوئیچ واسط یا دستگاه واسطی مانند Access Point یا DSLAM ارتباط می‌گیرد که خودش Option 82 را درج کرده است.

```
Switch(config) # ip dhcp snooping information option allow-untrusted
```

با فعال‌سازی این دستور، سوئیچ اجازه می‌دهد که پیام‌های DHCP حاوی فیلد Option 82 حتی اگر از پورت‌های غیرقابل اعتماد وارد شده باشند، به سرور DHCP منتقل شوند. این قابلیت زمانی کاربرد دارد که تجهیزات میانی مانند Access Point در ساختار شبکه مسئول درج فیلد Option 82 هستند و اطلاعات مکان‌یابی آنها برای تخصیص دقیق آدرس IP ضروری است.

تعریف پورت به عنوان قابل اعتماد

```
Switch(config) # interface FastEthernet01/  
Switch(config-if) # ip dhcp snooping trust
```

نکته: این دستور باید در هر دو طرف لینک (دو سوئیچ متصل) اعمال شود تا ارتباط معتبر تلقی شود.

محدودسازی نرخ ارسال درخواست‌های DHCP

در حالت پیش فرض هیچ محدودیتی بر نرخ ارسال درخواست‌های DHCP وجود ندارد.

```
Switch(config) # interface FastEthernet01/  
Switch(config-if) # ip dhcp snooping limit rate 50
```

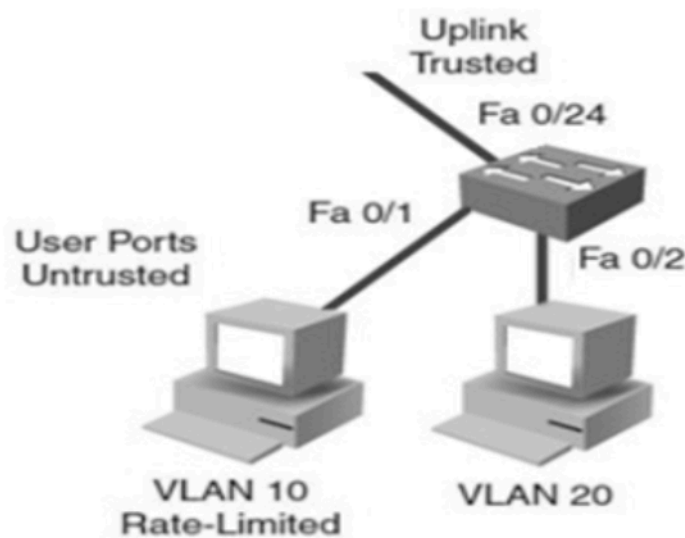
مشاهده تنظیمات DHCP Snooping

برای مشاهده وضعیت فعلی پیکربندی:

```
Switch# show ip dhcp snooping
```

مثالی از خروجی DHCP Snooping

برای مثال در شبکه‌ی شکل زیر دو VLAN 10 و VLAN 20 را داریم که برای هر دو DHCP Snooping فعال شده و خروجی دستور show ip dhcp snooping برای آن نمایش داده شده است.



شکل ۱: ساختار شبکه شامل دو VLAN و فعال‌سازی DHCP Snooping

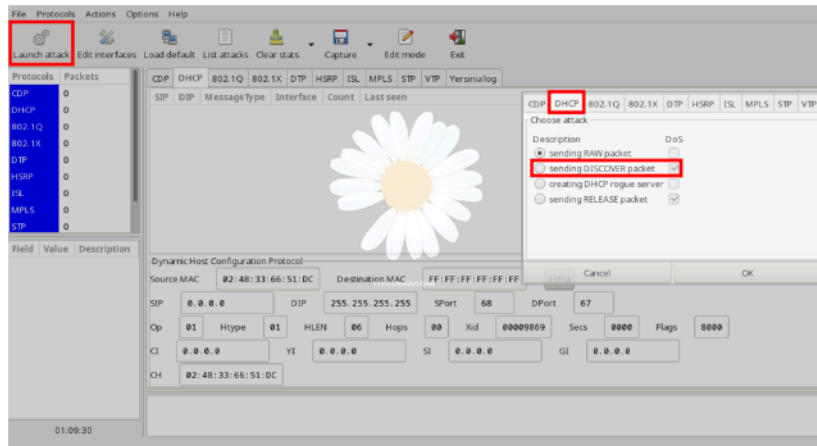
```
switch# show ip dhcp snooping
Switch DHCP snooping is enabled
DHCP snooping is configured on following VLANs:
10,20
DHCP snooping is operational on following VLANs:
10,20
DHCP snooping is configured on the following L3 Interfaces:
Insertion of option 82 is enabled
circuit-id default format: vlan-mod-port
remote-id: 001a.e372.ab00 (MAC)
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled
Verification of giaddr field is enabled
DHCP snooping trust/rate is configured on the following Interfaces:
```

Interface	Trusted	Allow option	Rate limit (pps)
FastEthernet0/1	no	no	5
FastEthernet0/24	yes	yes	unlimited

شکل ۲: خروجی دستور show ip dhcp snooping

حمله‌ی جعل DHCP (DHCP Spoofing)

ابزار Yersinia برای جعل DHCP استفاده می‌شود؛ ناگفته نماند ابزارهایی مانند Ettercap، DHCPig، Responder و ... نیز وجود دارند که می‌توانید مستندات آن‌ها را مطالعه کرده و با ویژگی‌های متناسب هر کدام آشنا شوید. از Yersinia می‌توان برای انجام حملات مختلف بر روی پروتکل‌هایی مانند STP manipulation، VLAN hopping، DTP، CDP hijacking، MAC flooding و ARP spoofing استفاده کرد.



شکل ۳: نمای اولیه اجرای نرم‌افزار Yersinia و انتخاب حمله DHCP Spoofing

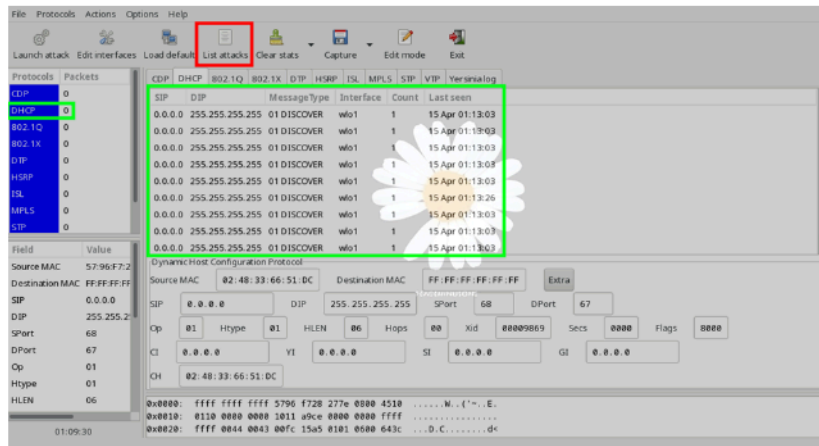
هنگامی که برنامه‌ی Yersinia را توسط دستور yersinia-G اجرا نمایید، با تصویر بالا مواجه خواهید شد. پس از زدن دکمه‌ی Launch attack، پنجره‌ای در سمت راست تصویر بالا باز می‌شود. در این پنجره می‌توانید از بین پروتکل‌های مختلف، نوع حمله را انتخاب کرده و سپس بر روی OK کلیک نمایید. در اینجا ما از منوی بالا DHCP را انتخاب کرده و نوع Sending DISCOVER packets را برمی‌گزینیم. در این حالت تعداد زیادی بسته‌ی DHCP DISCOVER ارسال می‌شود که باعث از کار افتادن DHCP Server خواهد شد.

همچنین می‌توانید با استفاده از گزینه‌ی DHCP rogue server، یک سرور جعلی DHCP راه‌اندازی کنید. این حالت زمانی به کار می‌رود که سرور اصلی DHCP ابتدا توسط مهاجم از کار انداخته شود و سپس سرور جعلی جایگزین آن گردد.

شکل ۴: تنظیمات ایجاد DHCP rogue server در نرم‌افزار Yersinia

پس از انتخاب گزینه‌ی نام‌برده، با صفحه‌ای روبه‌رو خواهید شد که باید فیلدهای مورد نیاز را پر کنید:

- در فیلد Server ID باید آدرس IP مهاجم وارد شود.
 - در فیلدهای Start IP و End IP محدوده‌ی آی‌پی‌هایی مشخص می‌شوند که قرار است سرور جعلی به کلاینت‌ها اختصاص دهد.
 - Lease Time زمان اعتبار تخصیص IP را مشخص می‌کند.
 - Renew Time مشخص می‌کند چه زمانی کلاینت مجدداً برای تمدید IP اقدام کند.
- سایر پارامترها نیز با توجه به شرایط شبکه قابل تنظیم‌اند.



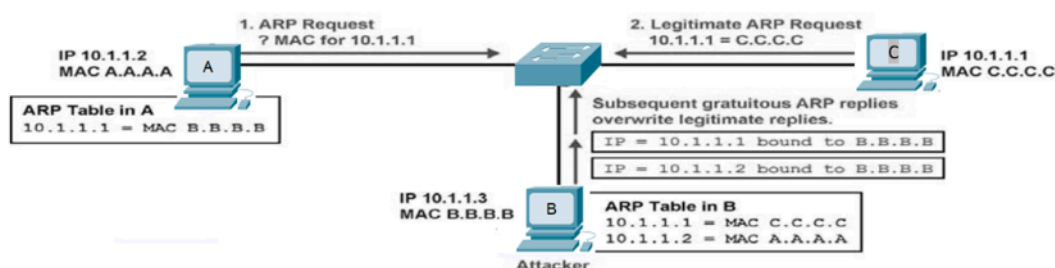
شکل ۵: متوقف سازی حمله از طریق List attacks و مشاهده ی بسته های ارسال شده

تذکره: معرفی این ابزار صرفاً جهت آموزش بوده و اکیداً توصیه می شود از آن در محیط های واقعی استفاده نگردد. این نوع فعالیت ها می توانند موجب اختلال جدی در شبکه شده و منجر به شناسایی سریع شما توسط مدیر شبکه شوند.

حمله ARP Spoofing

همانطور که در جلسات قبل گفته شد، جدول ARP یا همان ARP Table شامل اطلاعات آدرس فیزیکی (MAC) دستگاه‌های متصل به شبکه است (با MAC Table متفاوت هست). این جدول توسط پروتکل ARP برای ترجمه آدرس‌های IP به آدرس‌های MAC استفاده می‌شود. هنگامی که دستگاهی در شبکه‌ی محلی بخواهد با یک دستگاه دیگر در شبکه‌ی محلی خودش ارتباط برقرار کند، از جدول ARP استفاده می‌کند تا آدرس MAC دستگاه مورد نظر را پیدا کند و بتواند اطلاعات را برای آن ارسال کند.

فرض کنید دو میزبان A و C در یک شبکه محلی داریم. در صورتی که A بخواهد پیامی برای C بفرستد، این ارتباط در لایه ۲ و به کمک آدرس فیزیکی انجام می‌شود. میزبان A آدرس IP میزبان C را در اختیار دارد ولی برای این ارتباط نیاز به آدرس MAC میزبان C دارد. در این حالت، اگر در جدول ARP موجود در میزبان A، آدرس فیزیکی میزبان C وجود نداشته باشد، میزبان A یک درخواست ARP Request با آدرس IP میزبان C را روی کل شبکه‌ی محلی ارسال می‌کند تا میزبانی که این آدرس IP را دارد، آدرس فیزیکی خود را برای A ارسال کند.



شکل ۶: ارسال درخواست ARP برای کشف آدرس MAC مقصد

در حمله‌ی ARP Spoofing یا ARP Poisoning، مهاجم خودش را به عنوان یک دستگاه دیگر در شبکه جا می‌زند. به طور دقیق‌تر، مهاجم در پاسخ به درخواست‌های ARP ارسال شده برای یک آدرس IP خاص در شبکه (که این IP متفاوت با IP مهاجم است)، آدرس فیزیکی خودش را به عنوان پاسخ برای درخواست‌کننده ارسال می‌کند. این حمله باعث می‌شود که ترافیک شبکه به سمت مهاجم هدایت شود و او قادر خواهد بود تا اطلاعاتی که قرار بود برای میزبان دیگری ارسال شود را به‌طور غیرمجاز دریافت کند.

دفاع در برابر (ARP Spoofing) Dynamic ARP Inspection

برای مقابله با حملات ARP Spoofing، از Dynamic ARP Inspection یا به اختصار DAI استفاده می‌شود. DAI همانند ویژگی DHCP Snooping پورت‌های سوئیچ را به دو دسته‌ی قابل اعتماد و غیرقابل اعتماد تقسیم می‌کند و امکان محدودسازی نرخ ارسال بسته‌های ARP را نیز فراهم می‌نماید.

DAI بسته‌های ARP از پورت‌های قابل اعتماد را بدون بررسی عبور می‌دهد، ولی برای پاسخ‌های ARP ارسال‌شده از پورت‌های غیرقابل اعتماد، اعتبار آدرس‌های IP و MAC را بررسی می‌کند. برای انجام این کار، DAI باید تناظر IP-MAC را در اختیار داشته باشد که این اطلاعات توسط DHCP Snooping جمع‌آوری می‌شوند.

فعال‌سازی DAI روی شبکه‌های محلی مجازی خاص

```
Switch(config) # ip arp inspection vlan 10
```

با فعال‌سازی DAI، در حالت پیش‌فرض، تمامی پورت‌ها غیرقابل اعتماد هستند و نرخ مجاز بسته‌های ARP برابر با ۱۵ بسته بر ثانیه در نظر گرفته می‌شود.

تعریف پورت به عنوان پورت قابل اعتماد

```
Switch(config) # interface FastEthernet01/  
Switch(config-if) # ip arp inspection trust
```

مشخص کردن نرخ مجاز عبور بسته‌های ARP

```
Switch(config-if) # ip arp inspection limit rate 10 burst interval 1
```

در این دستور، منظور از pps نرخ ارسال بسته‌ها در هر ثانیه می‌باشد. همچنین، burst interval حداکثر بازه زمانی است که طی آن بسته‌ها می‌توانند به صورت موقت با نرخ فراتر از حد تعیین‌شده ارسال شوند. این بازه در حالت پیش‌فرض برابر با ۱ ثانیه در نظر گرفته شده است.

همان‌طور که گفته شد، در DAI، بسته‌های ARP دریافتی از لحاظ تطابق آدرس IP و آدرس MAC بررسی می‌شوند. با این حال، به کمک دستور زیر می‌توان سوئیچ را برای انجام بررسی‌های بیشتر پیکربندی نمود:

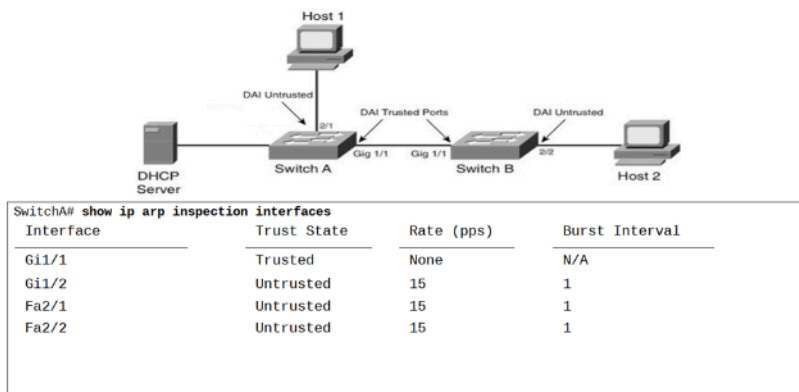
```
Switch(config-if) # ip arp inspection validate <options>
```

در این دستور می‌توان از گزینه‌های زیر استفاده کرد:

- src-mac : آدرس MAC فرستنده در بدنه‌ی بسته‌های ARP با آدرس MAC موجود در header بررسی می‌شود.
- dst-mac : آدرس MAC گیرنده در بدنه‌ی بسته‌های ARP با آدرس MAC موجود در header بررسی می‌شود.
- ip : آدرس IP در بسته‌های ARP بررسی می‌شود تا مشخص گردد که این آدرس‌ها معتبر بوده و جزو آدرس‌های منتظره یا تخصیص‌یافته هستند.

مشاهده تنظیمات DAI به صورت سراسری

```
Switch# show ip arp inspection interfaces
```



شکل ۷: نمایش وضعیت تنظیمات DAI روی سوئیچ

مشاهده تنظیمات DAI برای یک شبکه‌ی محلی مجازی خاص

برای مشاهده تنظیمات مربوط به یک VLAN خاص:

```
Switch# show ip arp inspection vlan 10
```

مشاهده جدول تناظر آدرس فیزیکی به آدرس IP

برای مشاهده جدول تطابق آدرس‌های IP-MAC که توسط DHCP Snooping تولید شده:

```
Switch# show ip dhcp snooping binding
```

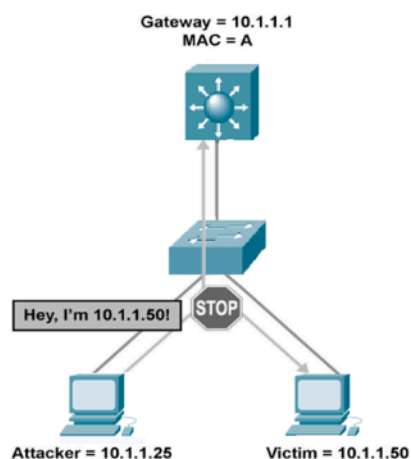
```
SwitchA# show ip dhcp snooping binding
```

MacAddress	IpAddress	Lease(sec)	Type	VLAN	Interface
00:01:00:01:00:01	10.10.10.1	4995	dhcp-snooping	10	FastEthernet2/1

شکل ۸: خروجی دستور show ip dhcp snooping binding برای بررسی جدول تناظر آدرس MAC و IP

حمله جعل (IP Spoofing) IP

حمله‌ی جعل IP، حمله‌ای است که توسط مهاجمان برای ارسال بسته‌هایی با آدرس IP مبدا نادرست و جعلی به منظور مخفی کردن هویت واقعی و جعل هویت دستگاهی دیگر در شبکه استفاده می‌شود. با جعل آدرس IP، مهاجم می‌تواند این‌گونه جلوه دهد که منبع بسته‌ها معتبر است. این کار شناسایی و مسدود کردن حمله را برای مدیران شبکه سخت‌تر می‌کند.



شکل ۹: شمایی از حمله جعل آدرس IP در شبکه

دفاع در برابر حمله‌ی جعل IP

برای مقابله با حملات جعل IP از قابلیت IP Source Guard (IPSG) استفاده می‌شود. IPSG نیز همانند DAI، اتصالات را به دو دسته‌ی قابل اعتماد و غیرقابل اعتماد تقسیم می‌کند.

برای پورت‌های غیرقابل اعتماد، بسته‌های ارسالی بررسی می‌شوند تا مطابقت آدرس IP مبدا با اطلاعات ثبت‌شده در جدول تناظر IP-MAC تایید شود. با فعال‌سازی IPSG، دستگاه‌های بخش غیرقابل اعتماد نمی‌توانند بسته‌هایی با آدرس جعلی IP ارسال کنند.

دستور فعال‌سازی IPSG

برای فعال‌سازی IPSG روی سوئیچ‌های لایه ۲ از دستور زیر استفاده می‌شود:

```
Switch(config) # interface FastEthernet01/
Switch(config-if) # ip verify source port-security
```

برای سوئیچ‌های لایه ۳ از دستور زیر استفاده می‌شود:

```
Switch(config) # interface FastEthernet01/
Switch(config-if) # ip verify source vlan dhcp-snooping
```

توجه: برای اجرای IPSG باید حتماً DHCP Snooping و Port-Security نیز فعال شده باشند.

دستور تعریف یک تناظر آدرس IP و آدرس MAC به صورت دستی

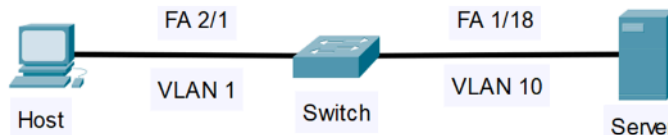
در شرایطی که از DHCP استفاده نمی‌شود، می‌توان تناظر آدرس‌های IP-MAC را به صورت دستی وارد کرد:

```
Switch(config) # ip source binding 10.0.0.5 vlan 10 interface FastEthernet02/
mac-address 0011.2233.4455
```

دستور نمایش پیکربندی IPSG

برای مشاهده تنظیمات جاری IP Source Guard در سوئیچ:

```
Switch# show ip verify source
```



```
Switch# show ip source binding
```

MacAddress	IpAddress	Lease(sec)	Type	VLAN	Interface
00:02:B3:3F:3B:99	10.1.1.11	6522	dhcp-snooping	1	FastEthernet2/1
00:00:00:0A:00:0B	10.1.10.1	infinite	static	10	FastEthernet2/18

```
Switch# show ip verify source
```

Interface	Filter-type	Filter-mode	IP-address	Mac-address	Vlan
Fa2/1	ip-mac	active	10.1.1.11	00:02:B3:3F:3B:99	1
Fa2/18	ip-mac	active	10.1.10.1	00:00:00:0A:00:0B	10

شکل ۱۰: نمایش پیکربندی IP Source Guard بر روی پورت‌های سوئیچ

ابزار hping3

با استفاده از hping3، کاربران می‌توانند بسته‌هایی با مقادیر مشخص برای فیلدهای مختلف، از جمله آدرس‌های IP مبدا و مقصد، نوع پروتکل، پرچم‌ها و محتوای دلخواه ایجاد و ارسال کنند. علاوه بر این، hping3 ویژگی‌هایی نظیر TCP/IP options, fragmenting و raw mode پشتیبانی می‌کند و به ابزاری قدرتمند برای تحلیل امنیت شبکه تبدیل شده است.

ابزارهایی مانند Scapy نیز وجود دارند که قابلیت‌های کامل‌تری برای ساخت بسته‌های دلخواه فراهم می‌کنند. برای مشاهده راهنمای کامل این ابزار می‌توان از دستور زیر استفاده کرد:

```
hping3 --help
```

برای ارسال یک بسته SYN جعلی به مقصد خاص با آدرس مبدا ساختگی:

```
sudo hping3 -c 1 -S -a 10.0.0.2 -p 80 192.168.1.10
```

در این دستور:

- -c 1: ارسال تنها یک بسته
- -S: ارسال بسته با فلگ SYN
- -a 10.0.0.2: جعل آدرس IP مبدا
- -p 80: ارسال به پورت ۸۰

تذکره: معرفی این ابزار صرفاً جهت اهداف آموزشی است. استفاده از این ابزار در شبکه‌های واقعی بدون مجوز ممکن است تبعات جدی داشته باشد!

امنیت اتصال به تجهیزات شبکه

مدیر شبکه برای مدیریت تجهیزات مانند سوئیچ‌ها و روترها از پروتکل‌های ارتباطی نظیر Telnet و SSH استفاده می‌کند. با توجه به امنیت پایین‌تر Telnet، استفاده از SSH به شدت توصیه می‌شود.

آسیب‌پذیری‌های Telnet

- تمامی داده‌ها (نام کاربری، رمز عبور و اطلاعات) به صورت متن منتقل می‌شوند.
- مهاجم می‌تواند با حملات DDoS سرویس Telnet را غیرفعال کند.
- دسترسی به حساب‌های مهمان یا ناشناس می‌تواند باعث نفوذ شود.

مزایای SSH

- ارتباط ایمن از طریق رمزنگاری کامل نشست‌ها.
- محافظت از رمز عبور در برابر شنود.
- استفاده از SSH v2 به جای v1 به دلیل امنیت بیشتر.

پیکربندی SSH در سوئیچ

برای فعال‌سازی ارتباط امن با سوئیچ از طریق SSH، مراحل زیر به ترتیب انجام می‌شوند:

۱. تعریف حساب کاربری محلی با سطح دسترسی کامل

```
Switch(config) # username admin privilege 15 secret admin123
```

در این مثال، کاربری با نام admin و رمز عبور admin123 با سطح دسترسی ۱۵ تعریف شده است.

۲. تعریف نام دامنه برای کلید رمزنگاری

```
Switch(config) # ip domain-name iut.ac.ir
```

در فرآیند تولید کلید رمزنگاری، دستگاه به یک نام یکتا نیاز دارد که از ترکیب hostname و domain-name ساخته می‌شود. این نام ترکیبی با عنوان FQDN (نام دامنه‌ی کامل) شناخته شده و به عنوان پایه‌ای برای تولید کلید دیجیتال مورد استفاده قرار می‌گیرد.

- هنگام اجرای دستور crypto key generate rsa، سوئیچ از FQDN برای تولید کلید عمومی و خصوصی استفاده می‌کند.
- کلیدها با این نام امضا می‌شوند و نقش مهمی در اعتبارسنجی هویت دستگاه دارند.
- در صورت عدم تعریف نام دامنه، دستور تولید کلید رمزنگاری اجرا نخواهد شد و پیغام خطا دریافت می‌شود.

۳. تولید جفت کلید RSA (رمزنگاری نامتقارن)

```
Switch(config) # crypto key generate rsa
How many bits in the modulus :[512] 2048
```

پیشنهاد می‌شود از کلیدهایی با طول ۲۰۴۸ بیت استفاده شود تا امنیت کافی فراهم گردد.

۴. (اختیاری) انتخاب نسخه‌ی امن‌تر SSH

```
Switch(config) # ip ssh version 2
```

نسخه ۲ نسبت به نسخه ۱ از الگوریتم‌های امن‌تری پشتیبانی کرده و در برابر حملات شناخته‌شده مقاوم‌تر است.

۵. (اختیاری) تنظیم پارامترهای امنیتی برای ارتباطات SSH

```
Switch(config) # ip ssh time-out 60
Switch(config) # ip ssh authentication-retries 3
```

در اینجا زمان انتظار برای ورود برابر با ۶۰ ثانیه و تعداد دفعات مجاز تلاش برای ورود ۳ بار تعریف شده است.

۶. پیکربندی خطوط VTY برای احراز هویت و فعال‌سازی SSH

```
Switch(config) # line vty 0 15
Switch(config-line) # login local
Switch(config-line) # transport input ssh
```

در این بخش، خطوط VTY که برای اتصال از راه دور (مانند SSH) استفاده می‌شوند، پیکربندی می‌گردند:

- `line vty 0 15`: VTY مخفف Virtual Teletype است و به خطوط مجازی‌ای گفته می‌شود که برای اتصال از راه دور به دستگاه (مانند SSH یا Telnet) استفاده می‌شوند. اعداد 0 تا 15 نشان‌دهنده‌ی شماره خطوط VTY هستند، که در این جا ۱۶ خط از شماره ۰ تا ۱۵ را شامل می‌شود. با این پیکربندی، حداکثر ۱۶ کاربر می‌توانند به صورت همزمان از راه دور به سوئیچ متصل شوند.

- login local: استفاده از نام کاربری و گذرواژه‌ای که روی خود دستگاه تعریف شده‌اند برای احراز هویت

- transport input ssh: فقط اجازه اتصال امن از طریق SSH و جلوگیری از Telnet

هدف از این پیکربندی، افزایش امنیت دستگاه و محدود کردن روش‌های دسترسی به روش رمزنگاری شده SSH است.

۷. (اختیاری) محدودسازی دسترسی با استفاده از لیست کنترل دسترسی (ACL)

```
Switch(config) # access-list 10 permit 10.1.1.0 0.0.0.255
Switch(config) # line vty 0 15
Switch(config-line) # access-class 10 in
```

در این مثال، تنها میزبان‌های داخل شبکه‌ی 10.1.1.0/24 مجاز به اتصال SSH به سوئیچ هستند.

پیکربندی اتصال از طریق HTTPS به سوئیچ

علاوه بر SSH و Telnet، می‌توان از طریق پروتکل‌های HTTP یا HTTPS نیز به کنسول مدیریتی سوئیچ متصل شد. با این حال، از بین این دو، استفاده از HTTPS به دلیل امنیت بیشتر، توصیه می‌شود.

غیرفعال‌سازی سرویس‌های HTTP و HTTPS

```
Switch(config) # no ip http server
Switch(config) # no ip http secure-server
```

فعال‌سازی دسترسی به کنسول از طریق HTTPS

مراحل زیر برای راه‌اندازی کامل HTTPS روی سوئیچ لازم است:

- تعریف حساب کاربری:

```
Switch(config) # username admin privilege 15 secret admin123
```

- اختصاص دامنه:

```
Switch(config) # ip domain-name iut.local
```

- تولید کلید رمزنگاری:

```
Switch(config) # crypto key generate rsa
How many bits in the modulus :[512] 2048
```

- غیرفعال کردن HTTP

```
Switch(config) # no ip http server
```

• فعال‌سازی HTTPS

```
Switch(config) # ip http secure-server
```

استفاده از احراز هویت محلی

```
Switch(config) # ip http authentication local
```

استفاده از ACL برای محدودسازی اتصال

ابتدا یک لیست کنترل دسترسی تعریف می‌شود:

```
Switch(config) # access-list 10 permit 10.1.9.0 0.0.0.255
```

سپس این لیست روی اتصالات مدیریتی اعمال می‌شود:

```
Switch(config) # ip http access-class 10
```

در این حالت فقط میزبان‌هایی که در محدوده آدرس 10.1.9.0/24 قرار دارند، امکان اتصال به کنسول از طریق HTTPS را خواهند داشت.

موفق و خنده رو باشید؛)